

Supplementary Material: Evidence Obligations and Replay Checks

Anonymous Authors

TABLE I
REPLAY LAYERS AND THEIR PURPOSE.

Layer	Purpose
Corpus capsules	preserve public source identity, commit, local license material, and byte digests
Extraction records	store normalized package and manifest facts for each pair
Admission outcomes	report profile-specific admitted/rejected decisions and missing evidence types
Projection outcomes	compare narrow downstream assumptions with the full admission rule
Construct checks	exercise weakening, preservation, adversarial, mutation, and parser-agreement relations
Reported quantities	regenerate all reported counts, tables, and figure coordinates from retained evidence
Digest summary	records sizes and SHA-256 digests for the reproducible evidence surface

I. SCOPE AND READING MAP

This supplement expands the evidence model, extraction rules, validation transformations, and replay checks used by the main paper. Its tables are derived from the same retained evidence summaries as the main paper.

The anonymized evaluation package uses retained local evidence and cached license/acquisition records only. It regenerates evidence summaries and validation outcomes without network, resolver, advisory, build, cloud, or credential-dependent operations.

II. EVIDENCE OBLIGATIONS AND ADMISSION RULE

The evidence universe is

$$\mathcal{O} = \{I, V, S, H, R, D, G, \Delta\}.$$

A manager adapter emits a parser state, normalized package records, manifest default and optional declarations, manager metadata, and an evidence vector $e \in \{0, 1\}^8$. The inventory profile requires $\mathcal{R}_{\text{inv}} = \mathcal{O} \setminus \{D\}$; the graph profile requires $\mathcal{R}_{\text{graph}} = \mathcal{O}$. The executable rule is

$$A_p(x) = 1 \iff \text{parsed}(x) \wedge \text{nonempty}(x) \wedge \mathcal{R}_p \subseteq \text{supp}(e_x).$$

The decision contains the subject identifier, profile, parser state, all eight evidence bits, eligibility, and an ordered missing-type list.

A. Finite properties

The replay enumerates all $2^8 = 256$ vectors for each of five manager labels and two profiles. For all 2,560 decisions it checks exact set-inclusion equivalence, monotonicity, graph-to-inventory refinement, and typed non-substitution. Manager labels are included in the replay grid to expose accidental manager dependence; they are not inputs to the policy kernel.

For each of five narrow projections, five managers, and two profiles, a constructive example retains exactly the projection-visible support while omitting one required evidence type. All 50 examples are accepted by the projection and rejected by the corresponding consumer profile. The table names the omitted evidence type and retained support.

III. MANAGER EXTRACTION CONTRACT

Adapters preserve markers and groups for diagnosis but do not convert them into dependency edges. Optional groups are excluded from the default agreement set. Direct and VCS references are integrity facts only when pinned; local source pointers are local facts. Explicit-source evidence is intentionally strict: an omitted default registry is not reconstructed.

The secondary parser has separate routines for manifests and every lock family. Agreement requires identical ordered package name/version records and identical evidence vectors. The comparison is performed for all 41 public subjects, not a sampled subset.

IV. CORPUS, TRANSFORMATIONS, AND ORACLES

The study materializes 41 public pairs from 57 screened rows. Sixteen excluded rows are retained with their reason. The included manager distribution and profile outcomes are reproduced below.

Each subject capsule contains only the evidence pair, local license material, an acquisition record, and a provenance note. The acquisition record stores public origin, fixed revision, evidence-object identifiers, and SHA-256 digests. The capsule audit recomputes all digests and rejects a row if the pair or license is missing, a recorded identity differs, or any byte digest changes. Repository popularity and manager ownership are not inclusion criteria. The corpus is a purposive, benchmark-scoped construct-validation benchmark, not a probability sample.

A. Transformations and oracles

Evidence removals start only from a base eligible for the targeted profile, remove one required typed coordinate, and call the normal decision kernel. Abstract vector attacks provide

TABLE II
OPERATIONAL EVIDENCE SPECIFICATION.

Type	Positive fact	Rejection condition
<i>I</i> identity	every normalized record has a canonical name	empty or conflicting identity in any record
<i>V</i> version	every record has a locked version or commit-resolved source	unconstrained/missing version or unpinned VCS source
<i>S</i> source	explicit registry/source, direct URL, VCS, or local source pointer	source depends only on an unstated default or machine configuration
<i>H</i> integrity	every record has hashes or a pinned/local fact	one or more records have no accepted fact
<i>R</i> epoch	schema, revision, content hash, or generated epoch	no serialized resolver-era marker
<i>D</i> edge	at least one package-to-package relation	only flat inventory, groups, order, or comments
<i>G</i> metadata	manager-specific generated metadata is parsed	format inferred only from container naming or manager label
Δ agreement	all default manifest declarations occur in lock inventory	at least one default direct dependency is absent

TABLE III
ADAPTER-SPECIFIC EVIDENCE LOCATIONS.

Manager	Manifest declarations	Package records	Metadata/epoch	Source, integrity, and relation evidence
PDM	PEP 621 project dependencies	TOML package tables	metadata, strategy, groups, content hash	source/files objects; dependency tables
pip-tools	input requirement lines	compiled pinned lines	generated header and command	explicit index directives; continuation hashes; no authoritative graph
Pipenv	default package declarations	JSON default/develop objects	manager metadata, manifest hash, specification marker	source list, indexes, per-package hashes; no transitive graph
Poetry	Poetry or PEP 621 declarations	TOML package tables	generated metadata, lock version, content hash	package sources, file hashes, dependency tables
uv	PEP 621 project dependencies	TOML package tables	schema, revision, Python requirement	package sources, artifacts, dependency arrays

TABLE IV
INCLUDED PAIRS AND OUTCOMES.

Manager	Pairs	Inventory	Graph
PDM	5	1/5	1/5
pip-tools	15	0/15	0/15
Pipenv	5	5/5	0/5
Poetry	10	1/10	1/10
uv	6	6/6	6/6
Total	41	13/41	8/41

coverage for manager/profile cells without an eligible public base. Preservation relations reverse package order, reverse hash order, add irrelevant metadata, and reorder optional groups. Formatting transformations perform a whitespace-preserving copy of every public manifest/lockfile pair and then reparse the result.

The case counts are derived from the admission rule and included bases. They are not manually selected: adding a required evidence type enlarges the truth table and non-substitution checks; adding an eligible public subject generates its profile-specific typed attacks and relations.

V. DIAGNOSTIC RESULTS AND REPLAY AUDIT

All included files preserve identity, version, resolver epoch, and manager metadata. Missing source identity is concentrated in PDM (4), pip-tools (15), and Poetry (9). Incomplete integrity occurs in 14 pip-tools and two Poetry pairs. Edges are absent from all pip-tools and Pipenv pairs and one PDM pair. Four pip-tools pairs fail default manifest agreement. These counts describe the included bytes and must not be interpreted as ecosystem prevalence or manager ranking.

The five narrow projections produce 341 over-admissions across 820 paired decisions: parser, name/version, and metadata each contribute 61; integrity contributes 29; manifest-subset agreement contributes 53. Projection overlaps are counted separately because each contract hides a different set of profile requirements.

The package table contains 2,050 records with name, version, hash count, source anchor, integrity fact, dependency count, groups, and marker. It permits a false Boolean coordinate to be localized to concrete records. The decision kernel never branches on package count, manager, public origin, subject identifier, or storage location.

A. Replay guarantee

The offline replay is an evidence audit rather than a procedural recipe. It reconstructs the evidence tables from retained

TABLE V
EXECUTABLE MUTATION FAMILIES.

ID	Target	Transformation	Expected relation
M01	identity	blank/remove a normalized package identity	eligible → ineligible
M02	version	remove a locked version	eligible → ineligible
M03	source	remove recognized source tables, objects, URLs, and local source pointers	eligible → ineligible
M04	integrity	remove hashes and pinned/local facts	eligible → ineligible
M05	epoch	remove schema, revision, generated hash/header	eligible → ineligible
M06	edge	remove normalized dependency relations	graph eligible → ineligible
M07	metadata	clear manager-specific lock metadata	eligible → ineligible
M08	agreement	add a default declaration absent from the lock	eligible → ineligible
M09	partial integrity	uncover one package while retaining other hashes	eligible → ineligible
M10	source relocation	replace explicit source with no local fact	eligible → ineligible
M11	empty inventory	remove all package records	usable → unusable
M12	parser state	force an extraction error	any profile → ineligible

TABLE VI
CONSTRUCT-VALIDATION OUTCOMES. THE INTENDED RELATION IS PASS
EQUALS CASES; BOLD PASS COUNTS MARK SUITES WITH COMPLETE
ORACLE AGREEMENT.

Validation suite	Pass	Cases
Evidence removals	155	155
Adversarial vectors	176	176
Metamorphic relations	319	319
Executable mutations	239	239
Formatting transformations	41	41
Independent-parser comparisons	41	41

capsules, rechecks the admission kernel, regenerates the quantities used by the main paper and supplement, and verifies that reported values agree with those quantities. A successful replay records the same high-level study status, evidence-number consistency, package layout, and digest closure.

The expected high-level values are 41 subjects, 2,050 package records, 13 inventory-eligible pairs, 8 graph-eligible pairs, 341 projection over-admissions, 971 controlled cases, and 2,560 finite decisions. Timing and PDF object bytes may vary by host. Admission results, row-level decisions, and SHA-256 evidence digests are host-independent.

B. Audit invariants

The package audit enforces a small public surface, rejects transient build products and environment-specific locations, verifies source syntax, checks public interfaces, and recomputes corpus-capsule digests. The document audit checks page allocation, citation closure, anonymous metadata, and evidence-number consistency.

The replay manifest is written only after the study, validation suites, document build, and audits pass. Each row records an anonymized package entry, byte size, and SHA-256 digest. An interrupted or inconsistent replay cannot produce the passing summary, preventing a stale success marker from masking incomplete evidence.

TABLE VII
CONSUMER-PROXY COMPARISON. ROWS ARE READ WITHIN EACH
CONSUMER; LOWER OVER-ADMISSION IS STRONGER, AND BOLD ZERO
MARKS NO OVER-ADMITTED SUBJECT/PROFILE CELLS FOR THAT PROXY.

Consumer	Baseline	Accepts	Over-admits
SBOM inventory	Parser	41/41	28
SBOM inventory	Name/version	41/41	28
SBOM inventory	SBOM proxy	13/41	0
SBOM inventory	Vuln graph proxy	8/41	0
SBOM inventory	Repro lock proxy	13/41	0
Vulnerability matching	Parser	41/41	33
Vulnerability matching	Name/version	41/41	33
Vulnerability matching	SBOM proxy	13/41	5
Vulnerability matching	Vuln graph proxy	8/41	0
Vulnerability matching	Repro lock proxy	13/41	5
Reproducible input	Parser	41/41	28
Reproducible input	Name/version	41/41	28
Reproducible input	SBOM proxy	13/41	0
Reproducible input	Vuln graph proxy	8/41	0
Reproducible input	Repro lock proxy	13/41	0
Dependency graph	Parser	41/41	33
Dependency graph	Name/version	41/41	33
Dependency graph	SBOM proxy	13/41	5
Dependency graph	Vuln graph proxy	8/41	0
Dependency graph	Repro lock proxy	13/41	5

The semantic invariant is fail-closed: missing inputs, parser errors, unknown profiles, and missing evidence never become eligible. The packaging invariant is also fail-closed: a missing required output, unexpected top-level entry, or document inconsistency makes the replay return a nonzero status.

VI. REJECTED PAIRS AND CLAIM SCOPE

A rejected pair is not a package-manager failure; it lacks a fact required by the named consumer profile. The counts validate the included capsules, profiles, and admission rule, not prevalence, manager ranking, or predictive accuracy.